



AT Protocol 上的 Handle 身份

从 Auth0 到 Aesthetic Computer 上的去中心化登录

ATProto OAuth、Handle 验证与可移植创意身份

@jeffrey

Aesthetic.Computer

ORCID: 0009-0007-4460-4913

<https://aesthetic.computer>

[工作草稿 — 请勿引用]

摘要。Aesthetic Computer 目前通过 Auth0 对用户进行身份验证，并在自托管的 AT Protocol 个人数据服务器 (PDS) at.aesthetic.computer 上维护一个并行身份。每个已验证用户都会获得一个 DID 和一个 PDS handle，但身份验证流经一个集中式 OAuth 提供者。我们建议通过采用 AT Protocol OAuth [Bluesky PBC, 2024d] 作为主要登录方法来合并这种双重身份架构，使任何拥有 Bluesky 或 ATProto 身份的人都能直接进行身份验证，并在 Aesthetic Computer 上获取相应的 handle。本文审视了 AT Protocol 身份栈 [DID、handle 验证、带有 DPoP 和 PAR 的 OAuth 2.1] [pckt.blog] 及其他 ATProto 原生应用如何实现去中心化登录 [pckt.blog, 2025]，映射了当前 AC 身份验证架构，并提出了从 Auth0 依赖到 AT Protocol-优先身份的分阶段迁移方案。核心论点是：在一个已经运行自己的 PDS 并铸造自己的 DID 的平台上，集中式身份提供者是退化器官。移除它可以简化技术栈，消除付费依赖，并使 AC 成为联邦社交网络的一等公民。

1. 引言

网络上的身份是一个房东问题。你不拥有你在 Twitter 上的 handle、在 Instagram 上的用户名，或在任何可以删除你账户的平台上的登录凭证。AT Protocol [Bluesky PBC, 2024e] [Bluesky] 背后的去中心化社交网络协议 [提出了一种不同的安排：你的身份是一个密码学密钥对，你的 handle 是你控制的域名，你的数据存储在一个你可以在提供者之间迁移的个人数据服务器上。

Aesthetic Computer 自 2024 年以来一直运行着一个混合身份系统。Auth0 [Auth0 by Okta, 2024] 处理身份验证：带有 PKCE 的 OAuth 2.0、刷新令牌和一个托管用户数据库。另外，一个自托管的 PDS 在 at.aesthetic.computer 上为每个已验证用户铸造 AT-Proto 身份。结果是一个重复的系统：每个用户两个身份、两个凭证存储、两条 handle 同步路径，以及一个付费的 Auth0 订阅来弥合差距。

本文提出的问题是：如果 PDS 就是身份提供者呢？

答案不是假设性的。pckt.blog [pckt.blog, 2025] 是一个构建在 AT Protocol 上的博客平台，完全通过 AT Protocol OAuth 对用户进行身份验证。用户使用他们的 Bluesky handle、自托管的 PDS 或任何兼容的身份提供者登录。没有 Auth0，没有 Firebase，没有集中式用户数据库。内容使用来自 Standard.site [Standard.site, 2025] 的共享词汇表同步到用户自己的 PDS。

我们考察这一模型如何适用于 Aesthetic Computer [一个拥有 600 多个交互作品、多人游戏会话、KidLisp 编

程语言和原生裸机操作系统 [jeffrey, 2026] 的创意计算平台 [并提出一个保持向后兼容性的分阶段迁移方案，同时向去中心化身份迈进。

2. 当前架构

2.1 Auth0 作为身份提供者

身份验证通过 Auth0 的 SPA SDK 进行。页面加载时，boot.mjs 检查 localStorage 中缓存的 Auth0 状态。如果存在会话（或检测到 OAuth 回调），它将使用 PKCE 和刷新令牌初始化 Auth0 客户端，交换授权码获取访问令牌，并检索用户配置文件。Auth0 的 sub 字段（例如 auth0|abc123 或 google-oauth2|xyz）作为内部用户标识符。

```
// boot.mjs: current Auth0 flow
const auth0 = await createAuth0Client({
  domain: "hi.aesthetic.computer",
  clientId: "LVdZaM...",
  cacheLocation: "localStorage",
  useRefreshTokens: true,
});
const user = await auth0.getUser();
// { sub, email, email_verified, ... }
```

2.2 Handle 系统

Handle 存储在 MongoDB 的 @handles 集合中，将 Auth0 的 sub 映射到 1-16 个字母数字字符的字符串（允许 . 和 _）。验证强制要求不能以标点符号开头/结尾、不区分大小写的唯一性和不良内容过滤。Handle 是面向用户的主要身份：可通过 URL 访问（@handle/piece-name）、在聊天中可见、由 AC Native OS 朗读。

2.3 ATProto 影子身份

在首次电子邮件验证时，Auth0 webhook 触发 createAtprotoAccount()，该函数：

1. 生成一个 32 字符的密码
2. 在 PDS 上创建邀请码
3. 在 handle.at.aesthetic.computer 上创建账户
4. 在 MongoDB 中存储 DID、handle 和加密密码（users.atproto）

当用户更改其 AC handle 时，updateAtprotoHandle() 将更改同步到 PDS。内容（绘画、心情、KidLisp 片段、磁带、新闻）通过六个自定义词汇表（computer.aesthetic.*）镜像到 PDS。ATProto 身份是真实且功能完备的 □ 但用户从未通过它进行身份验证。它是一个影子身份：存在的、同步的，但不是主权的。

2.4 重复问题

这种架构意味着：

- 两个凭证存储（Auth0 + PDS）
- 两个 handle 命名空间（AC handle + PDS handle）
- 两条同步路径（handle 变更传播 Auth0 → MongoDB → PDS）
- 一个付费依赖（Auth0 订阅）
- 没有互操作性（Bluesky 用户无法使用其现有身份登录 AC）

PDS 已经知道每个用户是谁。它已经存储了他们的 DID、他们的 handle、他们的内容。Auth0 层增加了成本和复杂性，却没有增加 PDS 无法提供的能力。

3. AT PROTOCOL 身份栈

理解迁移需要理解 AT Protocol 身份的三个层次：DID、handle 和 OAuth。

3.1 去中心化标识符（DID）

DID [W3C, 2022, Bluesky PBC, 2024b] 是一个持久的、可加密验证的标识符。AT Protocol 主要使用 did:plc，这是一种为强一致性、高可用性和不丢失身份的密钥轮换而设计的方法。每个 DID 解析为一个包含以下内容的文档：

- 用于验证仓库更新的签名密钥（P-256 或 K-256）[Bluesky PBC, 2024a]
- 用于账户恢复的轮换密钥
- PDS 端点 URL
- 用户当前的 handle

DID 是稳定的身份。Handle 会变；密钥会轮换；PDS 提供者来来去去。DID 持续存在。AC 已经通过其 PDS

为每个用户铸造 DID。基础设施已经存在。

3.2 Handle 验证

AT Protocol handle [Bluesky PBC, 2024c] 是一个双向解析到 DID 的域名。验证使用两种方法：

DNS TXT：在 _atproto.example.com 放置一条记录：

```
_atproto.example.com TXT "did=did:plc:abc..."
```

HTTPS Well-Known：在以下地址提供 DID：

```
GET /.well-known/atproto-did
Response: did:plc:abc...
```

两种方法都要求 handle 解析到 DID，且 DID 文档声明该 handle。这种双向验证意味着：如果你控制域名，你就控制了 handle。没有中央机构分配 handle；DNS 就是权威。

对于 AC，这意味着 jeffrey.at.aesthetic.computer 是一个真实的、可验证的 ATProto handle，因为 AC 同时控制 DNS 和 PDS。但这也意味着已经拥有 alice.bsky.social 或 alice.dev 的用户拥有一个 AC 可以信任的密码学验证身份 □ 无需密码。

3.3 ATProto OAuth

AT Protocol OAuth 规范 [Bluesky PBC, 2024d] 扩展了 OAuth 2.1，增加了三个强制性安全机制：

PKCE（Proof Key for Code Exchange）[Sakimura et al., 2015]：防止授权码拦截。客户端生成一个随机验证器，随授权请求发送其哈希值，并在令牌交换时证明持有原始验证器。

PAR（Pushed Authorization Requests）[Lodderstedt et al., 2021]：客户端在重定向用户之前通过 POST 向授权服务器提交授权参数。这防止了重定向 URL 中的参数篡改。

DPoP（Demonstrating Proof of Possession）[Fett et al., 2023]：每个请求包含一个签名 JWT，证明客户端持有与令牌关联的私钥。即使访问令牌泄露，也不能被其他客户端使用。

3.3.1 客户端标识

与传统 OAuth 不同，AT Protocol 不要求在每个授权服务器上预注册。相反，客户端在公共 HTTPS URL 上发布元数据：

```
// aesthetic.computer/oauth/client-metadata.json
{
  "client_id": "https://aesthetic.computer/...",
  "client_name": "Aesthetic Computer",
  "redirect_uris": ["https://..."],
  "grant_types": ["authorization_code"],
  "dpop_bound_access_tokens": true
}
```

任何 PDS 都可以通过获取此 URL 来发现和验证客户端。没有预共享密钥，没有应用商店注册，没有 API 密钥管理。

3.3.2 流程

1. 用户输入其 handle (例如 `alice.bsky.social`)
2. 客户端解析 handle → DID → PDS 端点 → 授权服务器
3. 客户端通过 PAR 推送授权参数
4. 用户被重定向到其 PDS 的授权界面
5. 用户批准；PDS 带着授权码重定向回来
6. 客户端交换授权码获取 DPoP 绑定的访问令牌
7. 客户端验证返回的 DID 与预期身份匹配

与 Auth0 的关键区别：用户使用自己的服务器进行身份验证。AC 永远不会看到密码。PDS 无论是 Bluesky 的、AC 自己的还是自托管的实例 就是身份权威。

4. 案例研究：PCKT.BLOG

`pckt.blog` [pckt.blog, 2025] 是一个完全通过 AT Protocol OAuth 进行身份验证的博客平台。它的实现证明了 ATProto-only 身份验证对内容平台的实际可行性。

4.1 身份验证

用户通过输入其 ATProto handle 来登录。`pckt.blog` 解析 handle，发现授权服务器，并启动 OAuth 流程。用户在其 PDS 上批准 (Bluesky、Blacksky、自托管服务器)。`pckt.blog` 接收 DPoP 绑定的访问令牌和用户的 DID。不存储密码。不维护单独的用户数据库。

4.2 数据主权

内容使用 `Standard.site` 词汇表 [Standard.site, 2025] 同步到用户自己的 PDS：

- `site.standard.publication` — 博客集合
- `site.standard.document` — 单篇文章
- `site.standard.graph.subscription` — 关注关系

如果 `pckt.blog` 消失，用户的内容仍保留在其 PDS 上，可被任何兼容的阅读器访问。这就是 ATProto 的承诺：平台是一个视图，而不是一个孤岛。

4.3 对 AC 的启示

`pckt.blog` 证明了面向内容的平台可以完全基于 AT-Proto 身份运行。与 AC 的相似之处是直接的：

- `pckt.blog` 发布文章；AC 发布作品、绘画和心情
- `pckt.blog` 使用 `Standard.site` 词汇表；AC 有六个自定义 `computer.aesthetic.*` 词汇表
- `pckt.blog` 的用户在其 PDS 上拥有其内容；AC 已经将内容镜像到其 PDS
- 两者都是 Node.js/JavaScript 应用程序

差距在于：`pckt.blog` 是 ATProto 原生构建的。AC 有一个现有的 Auth0 用户群，需要优雅地迁移。

5. 提议的迁移方案

5.1 第一阶段：ATProto OAuth 作为辅助登录

在 Auth0 旁边添加“使用 Bluesky 登录”，而不移除 Auth0。

基础设施：

1. 在 `aesthetic.computer/oauth/client-metadata.json` 发布客户端元数据
2. 将 `@atproto/oauth-client-node` [Bluesky PBC, 2024f] 添加到后端
3. 创建两个新的 Netlify 函数：
 - `POST /api/atproto-auth/start` — 解析 handle、PAR、重定向
 - `GET /api/atproto-auth/callback` — 带 DPoP 的授权码交换
4. 在 Redis 中存储会话 (DID、handle、DPoP 密钥对、令牌)

客户端流程：`boot.mjs` 中新的“使用 Bluesky 登录”按钮触发 ATProto OAuth 流程。成功后，`window.acUSER` 从 ATProto 会话填充 (DID 作为 `sub`、handle、除非用户提供否则没有电子邮件)。作品 API 表面是相同的 作品看到一个有 handle 的用户，无论哪条身份验证路径创建了会话。

5.2 第二阶段：Handle 桥接

当用户通过 ATProto 登录时，将其 handle 桥接到 AC：

1. 从 ATProto handle 中提取用户名 (例如从 `alice.bsky.social` 中提取 `alice`)
2. 对照 AC 的 `@handles` 集合检查可用性
3. 如果可用且有效 (1–16 个字符，字母数字)，提供一键认领
4. 如果已被占用，检查现有所有者的电子邮件是否匹配 提供账户关联
5. 如果被其他人占用，提示选择替代方案
6. 在 MongoDB 中存储 DID ↔ AC sub 映射，用于未来登录

自定义域名 handle (例如 `alice.dev`) 要求用户手动选择 AC handle，因为域名本身可能不映射到有效的 handle 字符串。

5.3 第三阶段：身份关联

现有 Auth0 用户可以关联其 ATProto 身份：

1. 从账户设置中启动 ATProto OAuth
2. 成功后，将外部 DID 与 Auth0 sub 一起存储
3. 未来的登录接受两条身份验证路径
4. 内容可以选择性地同步到用户的外部 PDS (不仅限于 AC 的 PDS)

这一阶段将现有的 `users.atproto` 字段从影子身份转变为一等身份关联。

5.4 第四阶段：ATProto-优先

迁移验证完成后：

1. 新注册默认使用 ATProto OAuth (在 AC 的 PDS 上创建账户)
2. Auth0 作为现有用户的遗留路径保留
3. 随着用户关联其 ATProto 身份，逐步淘汰 Auth0
4. 移除 Auth0 依赖，消除订阅费用

5.5 PDS 路由

一个关键的架构决策：内容去哪里？

- 仅 Auth0 用户：内容同步到 AC 的 PDS（当前行为）
- 拥有外部 PDS 的 ATProto 用户：内容同步到他们的 PDS
- 在 AC PDS 上的 ATProto 用户：内容保留在 AC 的 PDS 上

这意味着后端同步函数（`media-atproto.mjs`、`painting-atproto.mjs` 等）需要一个条件路径：从用户的 DID 文档中解析用户的 PDS 端点，并写入该端点而不是假定 AC 的 PDS。

6. HANDLE 语义

Handle 是身份栈中对人类最可见的部分，迁移引发了关于 handle 含义的问题。

6.1 当前 Handle 模型

今天，一个 AC handle 是：

- 一个 1–16 个字符的字符串，先到先得
- 在 AC 命名空间内唯一
- 用于 URL（`@alice/painting`）、聊天和 OS 个性化
- 存储在 MongoDB 中，缓存在 Redis 中
- 镜像到 PDS 为 `alice.at.aesthetic.computer`

6.2 ATProto Handle 模型

一个 ATProto handle 是：

- 一个域名（任何有效的 DNS 名称）
- 双向验证对应一个 DID
- 通过 DNS 权威全局唯一
- 跨服务可移植

6.3 桥接两种模型

提议：AC handle 是映射到 DID 的别名。真相来源从 MongoDB 转移到 DID 层。多种登录方法（Auth0、ATProto OAuth）解析到同一个 DID，后者解析到同一个 AC handle。

对于 AC Native OS [Jeffrey, 2026]，handle 被写入启动分区的 `config.json` 中，这意味着设备身份由密码学身份支撑。启动屏幕上的“你好 @alice”意味着 Alice 的 DID、Alice 的签名密钥、Alice 的可移植身份，而不仅仅是配置文件中的一个字符串。

7. 开放问题

Handle 优先级。如果 `alice` 在 AC 上未被认领，但 `alice.bsky.social` 登录了，她应该自动获得它吗？先先得很简单但允许抢注。ATProto 验证优先更公平但增加了复杂性。

电子邮件要求。Auth0 提供经过验证的电子邮件用于账户恢复。ATProto OAuth 不保证电子邮件。AC 是否应该要求电子邮件才能使用完整的账户功能（购买、通知）？

多租户。AC 运营第二个租户（`sotce`），使用独立的 Auth0。ATProto 身份如何跨租户映射？DID 与租户无关，这可能简化跨租户身份。

会话服务器。实时功能（聊天、多人游戏）通过 Web-Socket 转发 Auth0 令牌进行身份验证。会话服务器必须接受 ATProto 发行的令牌或统一的会话令牌。

设备配对。AC Native OS 通过 Auth0 交换 6 字符代码进行配对。ATProto 等效方案：扫描 QR 码，在手机上启动 OAuth 流程，将令牌传送到设备。

管理员身份。管理员目前是 `handle === "jeffrey" && sub === ADMIN_SUB`。在 ATProto-优先身份验证下，管理员是 `did === admin_did` 更简洁，有密码学基础。

8. 相关工作

去中心化身份。W3C DID 规范 [W3C, 2022] 为去中心化标识符提供了正式框架。AT Protocol 的 `did:plc` 方法 [Bluesky PBC, 2024b] 通过强一致性保证和位于 `plc.directory` 的集中但可审计的目录对其进行了扩展。这是一个务实的折衷：身份解析的完全去中心化仍然是一个开放问题，`did:plc` 用一些去中心化换取了运营可靠性。

ATProto 原生应用。`pckt.blog` [pckt.blog, 2025] 展示了博客功能；`Leaflet.pub` 和 `Offprint.app` 通过 `Standard.site` [Standard.site, 2025] 在共享词汇表上协作。这些应用证明了 ATProto-only 身份验证对内容平台的可行性。

OAuth 安全性。DPoP [Fett et al., 2023] 防止令牌盗窃；PAR [Lodderstedt et al., 2021] 防止参数篡改；PKCE [Sakimura et al., 2015] 防止授权码拦截。它们共同代表了基于浏览器的 OAuth 安全的最新技术，显著强于 AC 目前使用的 Auth0 SPA 流程。

共生身份。伊利奇的共生工具 [Illich, 1973] 框定了这个问题：身份系统是扩展个人自主性，还是要求依赖于提供者？Auth0 是一个托管服务，方便但依赖。ATProto 身份是可移植的、可自我验证的、独立于提供者的。纳尔逊的个人计算愿景 [Nelson, 1974] 自然延伸到个人身份：你应该拥有你在网络上的名字。

9. 结论

Aesthetic Computer 已经运行着一个 PDS，铸造 DID，将内容同步到 ATProto 记录，并发布自定义词汇表。唯一缺失的部分是让用户通过该基础设施进行身份验证，而不是绕道 Auth0。迁移不是重写，而是移除一个变通方案。

分阶段方法（ATProto 作为辅助登录 → handle 桥接 → 身份关联 → ATProto-优先）确保不会打扰任何现有用户。最终状态：一个创意计算平台，你的 handle 是密码学身份，你的内容存储在你控制的服务器上，登录意味着证明你拥有你的密钥，而不是信任第三方为你担保。

PDS 已经在运行。DID 已经被铸造。词汇表已经发布。是时候让用户从正门登录了。

参考链接

AT Protocol 规范：

- <https://atproto.com/specs> — 完整协议规范
- <https://atproto.com/specs/oauth> — OAuth 规范
- <https://atproto.com/specs/handle> — Handle 解析
- <https://atproto.com/specs/cryptography> — 密码学方法
- <https://web.plc.directory/spec/v0.1/did-plc> — DID PLC 规范
- <https://atproto.com/guides/lexicon> — Lexicon 模式系统
- <https://atproto.com/guides/oauth-patterns> — OAuth 实现模式

实现指南：

- <https://docs.bsky.app/blog/oauth-atproto> — 构建 ATProto OAuth 应用
- <https://docs.bsky.app/docs/advanced-guides/resolving-identities> — 身份解析
- <https://docs.bsky.app/docs/advanced-guides/oauth-client> — OAuth 客户端指南

NPM 包：

- @atproto/oauth-client-node — Node.js OAuth 客户端
- @atproto/oauth-client-browser — 浏览器 OAuth 客户端
- @atproto/api — TypeScript XRPC 客户端
- @atproto/identity — DID/handle 解析
- @atcute/oauth-browser-client — 轻量级替代方案

参考实现：

- <https://github.com/pilcrowonpaper/atproto-oauth-example> — Astro OAuth 示例
- <https://github.com/bluesky-social/atproto> — ATProto 官方单体仓库
- <https://standard.site/docs/introduction/> — Standard.site 共享词汇表

使用 ATProto Auth 的应用：

- pckt.blog — 开放社交网络上的博客
- Leaflet.pub — 长文发布
- Offprint.app — 协作写作

IETF 标准：

- RFC 9449 — DPoP (Demonstrating Proof of Possession)
- RFC 7636 — PKCE (Proof Key for Code Exchange)
- RFC 9126 — PAR (Pushed Authorization Requests)

References

Auth0 by Okta. Auth0 Single Page App SDK. <https://auth0.com/docs/libraries/auth0-single-page-app-sdk>, 2024. JavaScript SDK for browser-based OAuth flows.

Bluesky PBC. At protocol cryptography specification. <https://atproto.com/specs/cryptography>, 2024a. P-256 and K-256 elliptic curve signing.

Bluesky PBC. Did plc specification v0.1. <https://web.plc.directory/spec/v0.1/did-plc>, 2024b. Decentralized Identifiers for AT Protocol.

Bluesky PBC. At protocol handle specification. <https://atproto.com/specs/handle>, 2024c. Handle resolution via DNS TXT and HTTPS well-known.

Bluesky PBC. At protocol oauth specification. <https://atproto.com/specs/oauth>, 2024d. OAuth 2.1 with PKCE, DPoP, and PAR for decentralized authentication.

Bluesky PBC. At protocol specification. <https://atproto.com/specs>, 2024e. Decentralized social networking protocol.

Bluesky PBC. @atproto/oauth-client-node. <https://www.npmjs.com/package/@atproto/oauth-client-node>, 2024f. Node.js AT Protocol OAuth client library.

Daniel Fett, Brian Campbell, John Bradley, Torsten Lodderstedt, Michael Jones, and David Waite. RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPoP). <https://datatracker.ietf.org/doc/html/rfc9449>, 2023. IETF standard for binding tokens to client key pairs.

Ivan Illich. *Tools for Conviviality*. Harper & Row, New York, 1973.

@jeffrey. Ac native os '26: A bare-metal creative computing operating system, 2026. Companion paper describing the AC Native OS.

Torsten Lodderstedt, Brian Campbell, Nat Sakimura, Dave Tonge, and Daniel Fett. RFC 9126: OAuth 2.0 Pushed Authorization Requests. <https://datatracker.ietf.org/doc/html/rfc9126>, 2021. Pushed Authorization Requests for OAuth.

Ted Nelson. *Computer Lib / Dream Machines*. Self-published, 1974. Revised edition 1987, Tempus Books/Microsoft Press.

pckt.blog. Blogging on the open social web and more exciting features. <https://devlog.pckt.blog/blogging-on-the-open-social-web-and-more-exciting-features-g9x55y6>, 2025. Development journal on ATProto blog integration.

Nat Sakimura, John Bradley, and Naveen Agarwal. RFC 7636: Proof Key for Code Exchange by OAuth Public Clients. <https://datatracker.ietf.org/doc/html/rfc7636>, 2015. PKCE for OAuth authorization code flow.

Standard.site. Standard site: Open blog publishing on at protocol. <https://standard.site/docs/introduction/>, 2025. Shared lexicons for blog content portability across AT-Proto.

W3C. Decentralized Identifiers (DIDs) v1.0. <https://www.w3.org/TR/did-core/>, 2022. W3C Recommendation for decentralized identifiers.